

# GxP Mandatory Training

Key Implementation Highlights for Developers

SAP Advanced Therapy Orchestration (ATO/CGT) | BTP Platform

Based on: GxP Training for CGT-TMP Team (2022-02-14) | Trainers: Mukul & Robin

Prepared: 2026-06-26 | Audience: All developers and testers touching the system

## What This Document Covers

|                    |               |                   |                   |                       |                       |                      |              |
|--------------------|---------------|-------------------|-------------------|-----------------------|-----------------------|----------------------|--------------|
| 1. Why GxP Matters | 2. GxP Basics | 3. 21 CFR Part 11 | 4. Data Integrity | 5. BTP Infrastructure | 6. Qualification Docs | 7. Client Agreements | 8. Dev Rules |
|--------------------|---------------|-------------------|-------------------|-----------------------|-----------------------|----------------------|--------------|

### ■ Mandatory

This training is MANDATORY. Every developer and tester who touches the system must complete it. Attendance is logged and is itself a GxP record — regulators can request to see training records during an audit.

*"When you are building a CGT platform, when you are running against timeline, these are very painful. But put yourself in that place — when we are trying to take a drug to a patient, was it doing these activities or not?" — Mukul, GxP Compliance Lead*

# 1

## Why GxP Matters for ATO/CGT Developers

*The reason compliance is non-negotiable in this platform*

### ■ Patient Safety First

The ATO platform moves clinical trial data and patient treatment data across supply chains. This data DIRECTLY drives which drug a patient receives and how it is manufactured. Incorrect data = incorrect drug = patient harm or death.

### ■ IT Systems Must Match Manual Controls

When IT platforms replaced manual processes, regulators required the SAME level of controls — traceability, attribution, integrity — that existed in paper-based processes. IT systems must deliver these controls AND more.

### ■ You Are Building a GxP-Regulated System

Every feature you build, every API you write, every table you design is part of a GxP-regulated system. Compliance is not a post-delivery task — it must be designed in from the start.

### ■ Non-Compliance Has Legal Consequences

Clients like Roche, Novartis, Gilead sign quality agreements with SAP. They can conduct announced AND unannounced audits. If your system fails an audit, SAP is liable. Individual developers are accountable through access records and audit logs.

### ■ Watch Out

Time pressure is NOT a valid reason to skip compliance activities. Every policy shortcut is itself a compliance violation and is recorded. If you are challenged for time, escalate — do not short-circuit the process.

## 2

## GxP Basics — What the 5 Pillars Mean for Your Code

*Every line of code touches at least one of these pillars*

| Pillar               | What It Means for Developers                                                                                                   | Implementation Examples                                                                                                         |
|----------------------|--------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Quality Management   | Every process you follow in SDLC must be documented. Risk assessments before development. Qualification standards for testing. | Risk assessment doc before sprint. Test plan for each feature. Qualification docs for infrastructure.                           |
| Change Management    | Every change to a regulated system must be controlled, tested with evidence, and traceable.                                    | No direct prod hotfixes. Every change linked to a test case. Evidence collected before deployment.                              |
| Access Management    | Only authorised users access regulated parts. Role-based access. Identity records maintained.                                  | RBAC implemented for all regulated transactions. No shared credentials. Access logs retained.                                   |
| Data Integrity       | All regulated data changes must be traceable — who changed what, when, old value, new value. 90% of audits focus here.         | Change Document Framework for CDHDR/CDPOS. Audit logs for every regulated field change. Data encryption at rest and in transit. |
| Training & Education | All personnel touching the system must be trained. Training is logged and auditable.                                           | This training session. Attendance record kept. Refreshers when regulations change.                                              |

### ✓ Remember

If you are unsure whether a feature impacts a regulated process — ask the GxP compliance team BEFORE building it, not after. Retrofitting compliance is far more expensive.

## 3

## 21 CFR Part 11 — What Developers Must Build

Electronic records and eSignature — decoded for implementation

■ **eSignature ≠ Fancy Technology**

In regulatory terms, eSignature = proving who took a decision, when, why, in an irrefutable way. A SAP user ID + password re-entry for a critical transaction is FULLY GxP-compliant. Biometrics (Pfizer, Roche) are optional enhancements — NOT requirements.

■ **What MUST Trigger eSignature**

Releasing a product. Moving product between stakeholders. Any action impacting patient safety. Changes to regulated fields (Therapy Type, Clinical Study, Protocol, Patient Reference). Rule: if a wrong decision here could harm a patient → eSignature required.

■ **What Does NOT Need eSignature**

Display-only activities (user just viewing data). Background/system job activities (automated processes run by system users — EXCLUDED by GxP rules). Non-regulated field changes (e.g. payment terms, delivery date).

■ **Logging Rule for Authentication**

If a user action enables a call that may impact patient safety → the authentication must be stored in a log. Display-only access → no logging required. Rule: patient safety impact = log it.

*"Even if it is ID and a simple password for a critical transaction — they are more than happy, as long as you follow those."  
— Mukul — confirming SAP password re-entry is GxP-compliant*

## Electronic Records Requirements — Build These Into Your Design

| Requirement     | What to Build                                                              | Do NOT                                                    |
|-----------------|----------------------------------------------------------------------------|-----------------------------------------------------------|
| Secured         | Data cannot be changed without leaving a trace — Change Document Framework | Allow direct table updates without audit trail            |
| Attributed      | Every record traceable to who created/modified it — USERNAME in CDHDR      | Use shared service accounts for regulated transactions    |
| Contemporaneous | Timestamped at time of action — UDATE + UTIME in CDHDR                     | Allow backdating or timestamp manipulation                |
| Original        | First capture or verified true copy of the data                            | Overwrite without keeping old value — use CDPOS VALUE_OLD |
| Accurate        | Data matches physical/clinical reality — validation at entry point         | Accept unvalidated external data without boundary check   |

## 4

## Data Integrity — ALCOA+ in Code

90% of regulatory audits focus here — design it in from day one

| A — Attributable                    | L — Legible                       | C — Contemporaneous                  | O — Original                        | A — Accurate                        | + Complete                          |
|-------------------------------------|-----------------------------------|--------------------------------------|-------------------------------------|-------------------------------------|-------------------------------------|
| Who created/changed it              | Readable and permanent            | Timestamped at occurrence            | First capture / true copy           | No errors or deviations             | Full lifecycle covered              |
| <i>USERNAME in every log record</i> | <i>No deletable audit records</i> | <i>UPDATE+UTIME at point of save</i> | <i>VALUE_OLD preserved in CDPOS</i> | <i>Validate at data entry point</i> | <i>Generation through archiving</i> |

#### ■ Data Lifecycle — ALL stages matter

Generation → Processing → Storage → Retrieval → ARCHIVING. Archiving is equally critical. Regulators ask: how long is data retained? Can you recover it? Design data archiving and retention policies from the start — not as an afterthought.

#### ■ External Data Sources

GxP-relevant external data: ask the provider to validate. If provider cannot validate: at YOUR data entry point (interface/data hub), verify that data received exactly matches data sent. Once verified — your responsibility ends. Document this boundary check.

#### ■ Data Corruption = Patient Risk

Millions of records flow through ATO for many clients. Data swapped or corrupted for a patient-specific cell therapy = adverse outcome = potential death. Regulators go to the Nth level to find root cause. Without audit logs → impossible to defend.

#### ■ Watch Out

Data integrity covers more than the database. Change control process, batch records, shipping records, stakeholder transfer records — ALL are data integrity. Regulators ask about ALL of these during audits.

# 5

## BTP Infrastructure Qualification

Cloud Service Qualification (CSQ) — how SAP keeps BTP GxP-compliant

### ■ Shared Responsibility Model

Client (Roche/Novartis/Gilead): validates their processes, interfaces, identity mgmt. SAP (SaaS vendor): qualifies the ATO application and BTP infrastructure layer. SAP BTP (PaaS): provides HANA, Workflow, Portal, Event Mesh — updates every 1-2 weeks. YOU as a developer: ensure your code does not break the qualification assumptions.

### ■ Why CSQ Exists

BTP services release hundreds of feature updates, security fixes, hot fixes continuously. It is impossible to review each individual change. Instead: define what you REQUIRE from each BTP service (intended use), then continuously test those requirements are still met. Deviation from expected behavior → escalate immediately.

### ■ Continuous Verification — What It Means for Your Code

Automated tests run every 5 minutes / hourly / daily verify BTP service behavior. Your solution components must have: defined intended use per BTP service, test cases linked to those requirements, deviation handling procedures. Traceability from SaaS application → solution component → BTP service → test evidence.

### ■ Data Encryption — Non-Negotiable

21 CFR Part 11 + open system consideration (BTP is an open system): data encryption at rest = MANDATORY for all electronic records. Data encryption in transit = MANDATORY. Do not store regulated data unencrypted at any layer.

| BTP Requirement            | Why Mandatory                                      | How Demonstrated                                       |
|----------------------------|----------------------------------------------------|--------------------------------------------------------|
| Data encryption at rest    | 21 CFR Part 11 + open system rule                  | BTP HANA encryption config + CSQ evidence              |
| Data encryption in transit | Electronic records in transit must be secured      | TLS/HTTPS enforced — no plain HTTP                     |
| Backup and restore         | Regulators ask: can you recover data? How quickly? | BTP backup config + tested restore procedure           |
| ISO 27001 certificate      | Baseline security assurance for BTP platform       | SAP BTP trust center documentation                     |
| SOC 2 Type 2 controls      | Independent audit of security controls             | SAP BTP SOC 2 report — useful but not sufficient alone |
| Change management for BTP  | Uncontrolled platform changes = compliance gap     | CSQ continuous testing + deviation handling            |

## 6

## Qualification Documents — What Clients Will Ask For

*If you cannot show it, it did not happen — document everything*

| Document             | What It Contains                                                                                                                  | Who Asks For It                                                        |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
| Traceability Matrix  | Epic → User Story → Requirements → Test Scripts → Test Results → Prod deployment. Every change linked to a test case.             | FIRST thing clients ask — most critical                                |
| Risk Assessment      | GAMP5-based: critical components, failure scenarios, severity, detectability. Conducted before development.                       | Clients + regulators in audit                                          |
| Design Specification | Documents the design approach and technical decisions.                                                                            | Clients during audit prep                                              |
| Test Plan            | How testing is conducted, who, when, what scope, what evidence collected.                                                         | Clients + internal QA                                                  |
| Validation Report    | Summary report generated after ALL testing activities complete. Final evidence package.                                           | Submitted to client before go-live                                     |
| IQ / OQ / PQ Docs    | Infrastructure Qualification (IQ), Operational (OQ), Performance (PQ) — confirm system works as intended at infrastructure level. | Clients operating in regulated markets                                 |
| Training Records     | Who was trained, when, on what topic. This session is one record.                                                                 | Regulators — 21 CFR Part 11 mandates training for all authorized users |

#### ■ Traceability Matrix — Build It as You Go

Do NOT create the traceability matrix at the end of a sprint. Link each user story → requirement → test case → test result → deployment as you develop. Retroactive creation is flagged by auditors as a compliance risk.

#### ■ Validation Report — Generated, Not Written

The validation report is generated by compiling all preceding evidence — design spec, test plan, test results, risk assessment. If you keep the artefacts current, the report writes itself. If you skip artefacts, you cannot generate the report.

*"Any change which goes into your platform — is it linked to a test case? How have you tested it? What are the activities? Right from epic, user story, to your requirements, to your test scripts and test results — that is the traceability matrix." — Mukul*

## 7

## Quality Agreements with Life Science Clients

*What Roche, Novartis, Gilead, Pfizer expect from SAP*

|                                                  |                                                                                                                                                                                                                                                                                 |
|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ■ <b>Quality Agreement is Mandatory</b>          | Every major Life Science client — Roche, Novartis, Gilead, Pfizer, Sanofi, Merck — requires a Quality Agreement SEPARATE from the commercial contract. This agreement defines exactly what GxP requirements SAP must fulfill.                                                   |
| ■ <b>Two Types of Audits — Be Ready for Both</b> | ANNOUNCED: client notifies SAP in advance — typically scheduled annually. UNANNOUNCED: client can walk in at any time without notice. The evidence package (documentation, audit logs, test results) must be ready ON DEMAND — not assembled after the audit is announced.      |
| ■ <b>No External Certificate Required</b>        | GxP compliance is SELF-ASSESSMENT backed by evidence. SOC 2 Type 2 is useful but not sufficient on its own — clients want to SEE the documentation, the audit logs, the traceability matrix, the test evidence. No third party certifies you as GxP compliant.                  |
| ■ <b>Chain of Identity and Chain of Custody</b>  | For CGT/ATO specifically: client's most critical requirement is tracing chain of identity (which patient's cells) and chain of custody (who had the product at every step). These are the primary regulatory drivers for all ATO field extensions and audit trail requirements. |



## 8

## 8 Key Rules for Developers

*Commit these to memory — they apply to every sprint, every story*

### No Shortcuts on Policies

1

Follow all policies and procedures even under time pressure. Everything is recorded. Short-circuiting a compliance process is itself a violation.

### Escalate Incidents Immediately

2

If you find a deviation, incident, or compliance gap — escalate, document, and regularize it. Do NOT ignore or work around it. Undisclosed incidents are far worse than disclosed ones.

### Every Change Linked to a Test Case

3

No story goes to production without a linked test case and test evidence. Traceability matrix is not optional — it is the first thing clients ask for.

### Audit Trail for ALL Regulated Changes

4

Who changed what, when, old value, new value. For ATO: this means CDHDR + CDPOS for every change to Therapy Type, Clinical Study, Protocol, Patient Reference fields.

### Access Control is Not Optional

5

Only authorized users access regulated parts of the system. No shared accounts. Access records must be maintained and auditable.

### Data Encryption at Rest and in Transit

6

Not optional for electronic records. BTP open system = encryption mandatory. Do not store regulated data unencrypted at any layer.

### Background Jobs Are Excluded from eSignature

7

System/technical user processes do not require reauthentication. Only human user-triggered critical transactions require re-authentication. Build this exclusion logic into the Relevancy Check callback.

### Training is a GxP Record

8

Attendance at this training is itself a regulated record. Keep records of who was trained, when, and on what. When team members join, ensure they complete training before accessing the system.

## 2022 Training → 2026 Implementation Mapping

| Training Requirement (2022)             | 2026 Implementation                                                |
|-----------------------------------------|--------------------------------------------------------------------|
| eSignature for regulated changes        | Reauthentication Framework + BTP eSignature SaaS                   |
| Audit trail — who, what, when, old/new  | Change Document Framework — CDHDR + CDPOS (verified 2608)          |
| ID + password re-entry is GxP-compliant | SAP password re-entry in reauthentication dialog — fully compliant |
| Reason for change must be captured      | Reason Code in reauthentication dialog (configured in BTP)         |
| System/background jobs excluded         | Reauthentication framework skips system-user triggered saves       |
| Signature linked to change record       | BTP Signature ID ↔ CHANGENR link in CDHDR                          |

|                               |                                                         |
|-------------------------------|---------------------------------------------------------|
| Traceability matrix mandatory | Epic → Story → Test Case → Test Result → CDHDR CHANGENR |
|-------------------------------|---------------------------------------------------------|